POPIA review pack

PODIUM — a four-week photography pilot at Aspire Fitness, Stellenbosch

Prepared for legal review · October 2026

Please read this first

This pack was drafted by an AI assistant, not by a lawyer, and it is not legal advice. Every statutory reference in it is a *pointer for you to check*, not a conclusion I am asserting. Where I have formed a view I have said so and said why, so you can disagree with it on the facts rather than guess at what the software does.

What I can tell you accurately is what the software actually does, because I built it and it is all verifiable. That is what Sections 2 and 3 are for.

What is being asked of you: read Section 4, and answer the nine questions in Section 5. Nothing starts until those are answered.

---

1. What the thing is, in plain terms

A member of a gym steps into a curtained corner with one light and one camera. A laptop records about **thirty seconds of video** while they hold three bodybuilding poses, plus one relaxed standing shot at the beginning.

Software picks the best still frame from each pose — five photographs in total — and shows them to the member, who chooses which (if any) to keep, and can send them to their own phone.

The point of the pilot is to find out which of two products this is: a **progress-measurement tool** people return to, or a **photo booth** people post from once. It runs for four weeks and then stops.

Scale: one gym, one laptop, roughly 120 sessions, adults only.

---

2. Exactly what is collected, and where it goes

Video	Never saved. The thirty seconds is processed frame by frame in memory and discarded. There is no video file to delete, because one is never written.
Photographs	Five stills per session, held on the laptop's local browser storage. Any the member does not explicitly choose are **deleted the same day, automatically**. Chosen ones are deleted after **180 days**.
Phone number	**Not stored.** It is converted on the laptop into a fixed scrambled string (a salted SHA-256 hash) used only to recognise a returning member. See the warning in Section 4, risk 1 — this is *pseudonymisation, not anonymisation*, and I believe it remains personal information.
Body outline	A set of coordinates describing where the member's limbs were, kept only if they keep their photographs, used only to show them where to stand next time. No face data.
Session record	One row per session with no image and no identifier in it: new or returning, one person or a group, which photographs were kept, how long they were inside. This is the pilot's actual output.
Consent record	What they agreed to, in which language, and a fingerprint of the exact text they read.

Nothing leaves the laptop. There is no server, no cloud account, no upload, no backup, no analytics, no third party. The only way a photograph leaves the device is the member themselves sharing it to their own phone, at the moment they choose to.

I believe that single design decision takes **section 72 (transfers outside the Republic)** off the table entirely, and reduces any security incident to one physical device. Please confirm I am right about that.

---

3. The consent text as it currently reads

This is shown on screen, in full, before anything is recorded. It takes about forty seconds to read. **It is a draft for you to change** — it lives in a plain text file precisely so a lawyer can rewrite it without a programmer.

> **Before we record anything**
>
> **Aspire Fitness · Stellenbosch** — read this, then decide. It takes less time than the photo does.
>
> **What happens in the next two minutes** A camera records about **30 seconds** of video while you hold three poses, with one relaxed shot at the start that we use for comparison. Software

picks the best still frame from each pose. You then look at the results and choose what happens to them. Nothing is kept unless you say so.

Where it goes: nowhere Everything stays **on this laptop**. There is no cloud, no upload, no account and no server. We do not send your photographs anywhere, and we could not retrieve them if you asked us to — only you can, from your own phone, at the moment you choose to share them.

If you share to WhatsApp or save to your phone, that copy is yours and this software has nothing further to do with it.

What we keep about you If you choose to keep your photographs so you can compare them next time, we store on this laptop:

- the photographs you chose to keep
- the date, and which poses you did
- an outline of your body position, so we can show you where to stand next time
- a **scrambled version of your phone number** — not the number itself

We scramble it so the laptop can recognise you next time without writing the number down. **It is not a perfect disguise.** Someone who had this laptop and wanted to badly enough could work the numbers back out, because there are only so many phone numbers in South Africa. So we treat it as information about you, not as anonymous: it is deleted when your photographs are, and we never use it to contact you.

If you would rather we held nothing derived from you at all, ask — we can give you a random code to keep on your phone instead, and then there is nothing on this laptop that came from you.

If you choose **Send and wipe**, we keep none of that. The photographs are deleted from this laptop immediately.

What we never do

- We do not identify you from your face or your body.
- We do not estimate your body fat, your weight, your health or your age.
- We do not sell, share or publish anything.
- We do not message you afterwards. If we ever want to, we have to ask you separately first.
- We do not record anyone who has not agreed. The curtain is closed and the camera cannot see past it.

How long we keep it Photographs you choose to keep are deleted after **180 days**. Anything you did not choose to keep is deleted the same day, automatically.

You can ask us to delete everything of yours at any point, including during your session, and we will do it in front of you. It takes about five seconds.

Your rights Under the Protection of Personal Information Act you can ask what we hold about you, ask us to correct it, ask us to delete it, and object to us holding it at all. You can also complain to the Information Regulator of South Africa.

> Ask the person running the pop-up, or contact **[CONTACT TO BE FILLED IN]**.
>
> **Why you have to be 18** We are not set up to handle photographs of anyone under 18, and the law treats that very differently. If you are under 18, we cannot record you today. There is no process to work around this.

How consent is actually taken

Three separate tick boxes, **none pre-ticked**, at the bottom of that text:

1. *I am 18 or older.* — **required**
2. *I agree to the 30-second recording.* — **required**
3. *Keep my photos on this laptop so I can see them next visit.* — **optional, off by default**

The button to continue stays dead until the first two are ticked. The third is deliberately separate and optional: agreeing to be photographed is not the same as agreeing to be remembered, and a member who declines it still gets their photographs to take away.

A returning member re-ticks all of this from scratch, every visit. Nothing required is carried over or pre-filled, including the age confirmation.

---

4. The risks, ranked by what would stop the business

Not ranked by what is easy to fix. Three of these are legal, and the legal ones are the ones that end companies rather than slow them down.

1. The member key is pseudonymous, not anonymous — ss 1, 19

This is the one I would most like you to look at.

A hashed phone number is not an anonymous one. South African mobile numbers are a space of roughly 100 million, and the scrambling key sits on the same laptop as the scrambled values — so anyone holding that laptop can work through the entire space in seconds and recover every number.

An earlier draft of the consent screen told members nobody could read the number back. **That was false, and it was on a screen they were agreeing to.** It has been corrected, and the text now says plainly that it is not a perfect disguise.

My reading: these records are **personal information** and every obligation that attaches to personal information attaches to them.

The alternative is already built: the software can instead issue a random six-character code the member keeps on their phone. Nothing stored is then derived from the person at all. The cost is not technical — members lose codes, and with the code goes their history. **This is a decision for you** (question 1 in Section 5).

2. Special personal information — ss 26–27

Section 26 prohibits processing biometric *or health* information without an exception under section 27, consent being the relevant one. Section 1 defines biometrics as a technique of personal **identification**.

Nothing here identifies anyone: the body-position maths is used to pick a good frame and is then discarded, and nothing is matched against anything. Nothing estimates body composition, weight, age or health, and the consent text says so explicitly.

But a photograph of a body, taken to show physical change over months, is at least arguably close to this line, and it certainly crosses it the moment anything infers a physical condition from the image. I have deliberately kept that out of the pilot for this reason.

3. Children — ss 34–35

Processing a child's personal information is prohibited unless an exception applies. A boutique gym with a strong Hyrox and running community will have 16- and 17-year-old members. **A self-declared tick box is weak evidence of age.**

The cheap control is the operator confirming against the gym's membership record at the counter. Whether that is required is question 3.

4. Who else is in frame

Bystanders have not consented to anything. The curtained corner is the consent boundary, and the camera must not see past it. This is an operational control, checked physically on day one, not a software one.

5. Consent quality — s 1 definition

Consent must be voluntary, specific and informed. A wall of text tapped through at a counter is none of those, and a pre-ticked box is the classic failure.

What has been done about it: plain language, about forty seconds to read, separate ticks for separate things, nothing pre-ticked, re-consent every visit. **Whether that clears the bar in a gym, at a counter, is your call** (question 4).

An Afrikaans version has not been written. The software supports it and has a language switch ready. I did not draft it because a consent text in a language I cannot verify is worse than an obvious gap (question 5).

6. Retention and deletion — ss 14, 24

Unkept photographs are deleted the same day, automatically, checked on startup and every ten minutes. Kept photographs expire after 180 days.

A member can demand deletion at any point and it is done in front of them — from the screen they are already holding, or by the operator on their behalf if they ring up a week later. The screen states what is about to go before it goes and what went afterwards.

A screen left untouched clears itself, with a warning first. If that happens at the point where the member is choosing photographs, the photographs are deleted there and then rather than waiting for the end-of-day sweep, and the visit is recorded as abandoned. This matters because the realistic privacy failure in a gym is not an attacker — it is the next person in the queue reading the screen the last one walked away from.

One judgement call in there needs your eye. A deletion removes the photographs, the body outline and the scrambled identifier outright. It does not remove the row recording that a session happened; it strips the identifier off that row and marks it as forgotten. My reasoning is that a row reading "one person, four minutes, two photographs kept, Tuesday" with no identifier on it is no longer information about anybody, and that deleting it instead would quietly falsify the only count the pilot exists to produce. I may have that balance wrong, and if I do the fix is one line (question 6).

Open question also: who performs a deletion request when the pop-up is not running, and how does a member reach us at all once the four weeks are over and the laptop is closed.

7. Security safeguards — s 19

One laptop in a gym is the single weakest point in this design. Required before the first session: full-disk encryption on, screen lock at one minute, no cloud sync on the folder, no shared login.

8. Breach notification — s 22

A stolen or lost laptop with kept photographs on it **is** a breach, notifiable to the Information Regulator and to affected members.

There is a real tension here: the design deliberately does not hold phone numbers, which is good for section 69 and awkward for section 22 — we would struggle to notify the people affected. Question 7 asks you to weigh that.

9. Responsible party vs operator — ss 1, 20–21

Someone is the responsible party. If it is the gym and we process on their behalf, we are an operator and sections 20–21 require a written agreement. If it is us, the obligations are ours. **This must be decided in writing before the pilot** (question 8). It determines who answers a complaint.

10. Direct marketing — s 69

Electronic direct marketing requires consent in a specific form. The design makes this moot by not holding a contact number at all. If that ever changes, it is a separate opt-in, not a reinterpretation of this one.

11. Misuse of the space

A private, curtained, well-lit room with a camera, in a gym. Sessions are fixed at thirty seconds and end themselves; nothing records outside a session. The operator stays within sight of the curtain. The rule for what happens if it is misused should exist before it is.

---

5. The nine questions

1. **Identity mode** — hashed phone number (convenient, reversible, stays in scope) or random member code (nothing derived from the person, members lose them)?
2. **Section 26** — on these facts, are these photographs special personal information? If yes, what changes in the consent wording?
3. **Age** — is a self-declared 18+ tick enough, or must the operator check the membership record?
4. **Consent quality** — does the current screen meet "voluntary, specific and informed" in this setting? What would you change?
5. **Afrikaans** — required, or is an English-only screen defensible in Stellenbosch for a four-week pilot?
6. **Deletion requests** — what is the process when the pop-up is not running, and how is it communicated?
7. **Breach notification** — how do we notify members we have deliberately chosen not to be able to contact? Does that change your answer to question 1?
8. **Responsible party** — the gym or us? Is an operator agreement needed, and can you draft the clause?
9. **Anything I have not asked about** that you would not let this run without.

---

6. What has deliberately been left out of the pilot

Said plainly so nobody adds it later without noticing:

- **No body-composition, health, weight or age estimation of any kind.** This is the line between a photograph and health information, and it is not crossed.
- **No face recognition, no identification, no matching.**
- **No cloud, no server, no backup, no account.** Adding any of these re-opens sections 19, 22 and 72 at once and should not happen without advice.
- **No messaging members afterwards.**
- **No floor scale.** Weight is not collected.
- **Nobody under 18.**

---

7. Where the actual files are

Everything is in a public GitHub repository, and the live app is a web page that stores nothing centrally. If it is useful to see it running rather than described, it takes about a minute.

The consent text, as an editable file	`pilot/consent/consent.en.md`
The empty Afrikaans slot	`pilot/consent/consent.af.md`
Privacy and retention settings in one place	`pilot/config.json`
The longer technical risk register	`pilot/RISKS-POPIA.md`
What the pilot is measuring and why	`pilot/DECISIONS.md`

Drafted by Claude (an AI assistant) for the PODIUM pilot, October 2026. Not legal advice. Every section reference is a pointer to check, not a conclusion.